DATHEON / APPLICATION SECURITY

Datheon Final Submission Guide

Datheon Application Security & API Pentesting Internship · 30 October–27 November 2026

Adil Firoz · Batch 01 · The Neotia University · B.Tech Computer Science and Engineering (Cybersecurity)

LOCAL SYNTHETIC-DATA TRAINING PORTFOLIO

Datheon Final Submission Guide

Repository

The target repository name is Datheon-Application-Security-API-Pentesting-Internship under GitHub user Adilfiroz24. Local project files are not proof of public publication. After GitHub CLI authentication, confirm the repository's visibility and verify the pushed feature branch and pull request from GitHub itself.

Verify the portfolio

1. Open the public repository URL once publication is complete.
2. Check all four task folders: Task-1-IDOR-Discovery, Task-2-BOLA-Remediation, Task-3-Session-Security, and Task-4-PII-Masking-DAST.
3. Review each task README, source implementation, test coverage, and evidence instructions.
4. Check the five generated reports and this guide PDF. Verify the PDFs are readable and correspond to the final test run.
5. Review the root README, OpenAPI file, Postman collection, CI workflow, and LinkedIn drafts.
6. Confirm no .env, passwords, tokens, or real personal information are present.

LinkedIn and Datheon submission

1. Review the drafts under docs/linkedin/; replace the repository placeholder only after publication and ensure every claim matches actual outcomes.
2. Publish only after review and any required organizational approval. Copy the resulting post URL from LinkedIn's share/link controls.
3. Submit the verified GitHub repository URL and LinkedIn URL using Datheon's official submission process.
4. Select only tasks that are complete and independently verified.
5. Reopen the submitted URLs and verify access, report availability, and selected assignment details.

The Datheon portal must be submitted manually by the student; this project does not submit forms or represent official certification.

Automated test execution

Vitest run: PASSED · 8/8 passed · 0 failed

Test case	RESULT	Duration
Task 1 and Task 2: object authorization keeps the vulnerable route disabled unless explicitly enabled	PASSED	128 ms
Task 1 and Task 2: object authorization keeps the vulnerable comparison reachable only on loopback with the explicit lab flag	PASSED	15 ms
Task 1 and Task 2: object authorization rejects unauthenticated access and prevents cross-user record reads	PASSED	76 ms
Task 3: cookie-based session security sets an HttpOnly, SameSite cookie and validates the session	PASSED	45 ms
Task 3: cookie-based session security requires CSRF validation and rotates then invalidates the prior token	PASSED	54 ms
Task 3: cookie-based session security returns a generic authentication error and applies brute-force throttling	PASSED	141 ms
Task 4: public data and response hardening masks dynamic PII and does not return the source values	PASSED	6 ms
Task 4: public data and response hardening sets baseline security headers and a restrictive CSP	PASSED	6 ms